ISC2 CERTIFIED IN CYBERSECURITY (CC)

Pass Plan & Study Guide

Aligned to the exam outline effective 1 September 2026



- **5 domain concept sheets**: tables, memory hooks, real-world cases, exam traps
- **110 original exam-style questions**: 60 domain drills + a 50-question weighted mock exam
- Every answer explained, with answer positions **balanced across A–D**
- 14-day weight-based plan, readiness gate, error log, 1-page final cheat sheet

Prepared for Charles Akl · November 2026 · Merged and corrected from the ChatGPT and Copilot drafts
Independent study material, not affiliated with or endorsed by ISC2. Questions are original practice items, not real exam questions.

What changed from your two drafts

Both earlier guides had real strengths. This edition keeps them, fixes the problems that would hurt your score, and fills the gaps against the September 2026 outline.

Draft	Kept	Problems found
ChatGPT Master Guide (55 pp)	Realistic banking/SRE case studies, scenario questions, 14-day plan, teach-back method.	**Answer bias:** at least 65 of its 80 multiple-choice answers are “B”, so you could score well by pattern, not knowledge. **Outdated structure:** built on the pre-2026 domain layout. **Repetition:** appendix duplicates the lessons; boilerplate repeated on every page. **Gaps:** no Code of Ethics canons, laws/frameworks, metrics, wireless/IoT, cloud deployment models, sanitization, threat-intel frameworks, red/blue/purple teaming.
Copilot Optimized Guide (~15 pp)	Correct 2026 domains and weights, contrast table, error log, readiness gate, “do not cram” list.	**Questions too thin:** 30 one-line prompts with no answer choices, so they don't train you to reject distractors the way the real exam requires. **Too compressed:** several required objectives reduced to one line or missing (same gaps as above, plus IPv4/IPv6, backups types, recovery sites, data states, order of volatility).
This edition	2026 domain order and weights · concise tables you can actually revise from · every newly listed objective covered · 110 four-option questions with explanations, answers balanced A–D (≈ 27–28 each) · weighted mock exam with per-domain scoring · one-page final sheet.	

Exam at a glance

100–125
items (25 unscored pretest)

2 hours
time limit

CAT
adaptive, no going back

700 / 1000
scaled passing score

Format reported for the 2026 outline: computerized adaptive testing, multiple-choice plus possible advanced item types. Because CAT adapts to you, a question feeling hard usually means you're doing well. **You cannot skip or return to questions**, so answer each one fully before moving on. Always confirm current details on isc2.org before booking.

Where the points are, and where your time goes

Domain	Weight		Study time (≈ 30 hrs)
1. Security Principles	24%		~7 hrs
2. Security Governance	17.3%		~5 hrs
3. Identity & Access Management (IAM) Concepts	20%		~6 hrs
4. Networking & Cloud Security Concepts	21.3%		~6.5 hrs
5. Security Operations & Incident Response	17.3%		~5 hrs

AI security concepts are not a separate domain; they are woven into all five (shadow AI, prompt injection, deepfakes, AI agent identities, AI acceptable-use policy). They're marked in each domain sheet.

How to answer CC questions

Think like a security manager, not a technician. The exam rewards the answer that is safe, authorized, follows process and addresses the stated objective, not the cleverest technical fix.

The 5-step decision method

1. **Find the asset and the objective at risk.** Confidentiality, integrity, availability, privacy, accountability?
2. **Find the qualifier.** BEST, FIRST, MOST, PRIMARY, LEAST, NOT. Circle it mentally; it decides between two “correct” answers.
3. **Name the phase or function.** Prevent, detect, correct, recover, govern or preserve evidence?
4. **Eliminate.** Strike answers that exceed your authority, destroy evidence, bypass approval, endanger people, or solve a different objective.
5. **Pick the most direct, organizationally appropriate answer.** Don't add facts that aren't in the stem.

Qualifier cheat-codes

Word	What it usually points to
FIRST	Follow the plan; ensure safety; contain; escalate/report; preserve evidence; verify scope before a permanent fix. In planning questions, the BIA, asset inventory or risk assessment.
BEST / MOST	Several answers work; choose the one that most directly and completely meets the stated objective with the least side-effect.
PRIMARY	The main purpose, not every benefit (e.g., a signature's primary purpose is integrity/authenticity, not confidentiality).
LEAST / NOT	Reversed question. Re-read the options as “which one does NOT fit.”

Priority order when answers compete

Human life & safety | Law & ethics | Policy & approved process | Contain / limit damage | Preserve evidence | Restore business | Improve

Answers that are almost always wrong

- Delete logs / reimage / reboot immediately
- Pay the ransom, hack back, or retaliate
- Share credentials or one-time codes
- Disable a control (MFA, logging, firewall) to “fix” a problem
- A security analyst accepting business risk alone
- Going public or to the media before the plan says so
- Trusting something because it's internal, urgent or looks familiar
- Skipping change control because it's faster

14-day plan & how to study

About 2 hours a day: **45 min learn → 15 min close the guide and explain it aloud → 45 min questions → 15 min error log.** Short on time? Compress to 7 days by pairing days (1+2, 3+4, 5+6, 8+9, 10+11, 12, 13+14).

Day	Focus	Do this
1	Baseline + D1	Take Domain 1 drill cold (no study). Start error log. Study CIA, privacy, AAA.
2	D1	Risk, treatments, ALE, controls, governance documents, Code of Ethics.
3	D2	GRC, laws & frameworks, awareness, KPIs/KRIs. Do D2 drill.
4	D2	BC/DR, BIA, MTD/RTO/RPO, sites, backup types, test types.
5	D3	Factors, MFA, biometrics, least privilege, SoD, need to know.
6	D3	DAC/MAC/RBAC/ABAC, lifecycle (JML), SSO/SAML/OAuth/OIDC, PAM. D3 drill.
7	Checkpoint	Redo D1–D3 drills closed-book. Re-learn every miss. Teach CIA→IAM aloud in 10 min.
8	D4	OSI/TCP-IP, IPv4/IPv6, private ranges, ports, insecure→secure pairs.
9	D4	Attacks & malware, firewalls, IDS/IPS, DMZ, VLAN, Zero Trust, wireless, IoT.
10	D4	Cloud characteristics, IaaS/PaaS/SaaS, deployment models, shared responsibility. D4 drill.
11	D5	Data lifecycle, sanitization, crypto (symmetric/asymmetric/hash/signatures/PQC), logging & triage.
12	D5	Threat actors & intel, IR phases & evidence, asset/config/change mgmt, security testing. D5 drill.
13	Mock exam	50-question mock in 60 minutes, no notes, no going back. Score by domain. Remediate.
14	Consolidate	Error log + contrast table + cheat sheet only. Light review, early night.

The study loop that works

1. **Learn** one sheet; link each term to its look-alike.
2. **Retrieve**: close the guide, explain aloud.
3. **Apply**: drill questions; say why each wrong option is wrong.
4. **Log** misses by *concept*, not question number.
5. **Re-test** misses after 1, 3 and 7 days.

Readiness gate: book the exam when…

☐ Mock exam ≥ 80% under time pressure

☐ No domain below 75%

☐ You can explain every contrast-table row without notes

☐ Every logged miss re-answered correctly after a delay

☐ You can say why the 3 wrong options are wrong

Recommended extra source: ISC2's free official CC self-paced training and the official exam outline. Use fresh questions; scores from memorized repeats don't count.

DOMAIN 1

Security Principles

24% of exam

What the exam wants: The vocabulary of security. Most questions test whether you can tell two similar terms apart (authentication vs authorization, threat vs vulnerability, due care vs due diligence) and pick the right control for the objective at risk.

CIA triad + privacy

Objective	Protects against	Typical controls	Example failure
Confidentiality	Unauthorized disclosure	Encryption, access control, data classification, masking	Public cloud bucket exposes customer records
Integrity	Unauthorized or accidental change	Hashing, digital signatures, change control, input validation	Attacker alters a payment amount in transit
Availability	Disruption of authorized access	Redundancy, failover, backups, DDoS protection, capacity	Ransomware or DDoS takes the site offline

Privacy is about the *proper* collection, use, retention and disclosure of personal data (PII/PHI). Key ideas: consent, purpose limitation, data minimization, data-subject rights. Confidentiality is a tool for privacy, not the same thing: you can keep data perfectly confidential and still violate privacy by collecting it without a lawful purpose.

AAA, identification and non-repudiation

Step	Question it answers	Example
Identification	Who do you claim to be?	Username, badge number, email
Authentication	Prove it.	Password + authenticator app
Authorization	What are you allowed to do?	Read-only access to the HR folder
Accounting / Auditing	What did you do?	Protected audit log entry

Non-repudiation: the sender cannot credibly deny the action. It comes from **digital signatures** (private key held only by the signer) plus protected logs. Shared accounts destroy non-repudiation and accountability.

Risk management

Asset (something of value) → **Vulnerability** (a weakness) → **Threat** (anything that could exploit it) → **Risk** = likelihood × impact.

- **Risk identification → assessment → treatment → monitoring.** Record it in a **risk register** with an owner.
- **Qualitative** = high/medium/low ratings (fast, subjective). **Quantitative** = money. SLE = Asset Value × Exposure Factor; ALE = SLE × ARO.
- **Inherent risk** exists before controls; **residual risk** remains after. Risk is never zero.
- **Risk appetite** = how much risk leadership is willing to pursue overall; **risk tolerance** = acceptable variation around it.

Treatment	Meaning	Example
Avoid	Stop the risky activity	Retire the legacy FTP server
Mitigate (reduce)	Add controls	Patch, add MFA, segment
Transfer (share)	Shift financial impact	Cyber insurance, outsourcing contract
Accept	Knowingly live with it	Documented sign-off by the **risk owner**

> Ignoring a risk (doing nothing, with no decision) is **not** acceptance. Only management / the business risk owner accepts risk. Transfer moves money impact, never accountability.

Security controls

By type (how)	Examples
Administrative (managerial)	Policies, training, background checks, separation of duties
Technical (logical)	MFA, firewalls, encryption, ACLs, EDR
Physical	Locks, fences, guards, bollards, cameras, mantraps

By function (what it does)	Examples
Preventive	Door lock, firewall deny rule, MFA
Detective	IDS, CCTV review, log monitoring, audits
Corrective	Restore from backup, patch after incident, quarantine malware
Deterrent	Warning banner, visible camera, guard dog sign
Recovery	DR site, rebuilding a server
Directive	Policy, "Authorized personnel only" sign
Compensating	Alternate control when the primary isn't feasible (e.g. extra monitoring on a legacy system that can't be patched)

Defense in depth: layer administrative + technical + physical controls so one failure is not a total compromise.

Governance elements

Document	Mandatory?	What it does	Example
Policy	Yes	High-level management intent, the "why/what"	"All sensitive data must be protected."
Standard	Yes	Specific, measurable requirement	"Passwords must be at least 14 characters."
Procedure	Yes	Step-by-step "how"	Help-desk password reset steps
Baseline	Yes	Minimum secure configuration	Windows server hardening build
Guideline	No	Recommendation / best practice	Tips for spotting phishing

Laws & regulations (from government, legally binding) sit above all internal documents. Organizational policy must comply with them.

Professional ethics: ISC2 Code of Ethics

Preamble: the safety and welfare of society and the common good, duty to our principals and to each other, require that we adhere to the highest ethical standards.

1. **Protect society**, the common good, necessary public trust and confidence, and the infrastructure.
2. **Act honorably, honestly, justly, responsibly and legally.**
3. **Provide diligent and competent service to principals** (employers / clients).
4. **Advance and protect the profession.**

> **Memory hook: "Society, Honor, Principals, Profession."** When canons conflict, apply them **in order**: protecting society beats pleasing your employer. Complaints must come from someone harmed: canons 1 & 2 by anyone, canon 3 by principals, canon 4 by professionals.

Due care = doing what a reasonable person would do (implementing and operating the controls). **Due diligence** = the research and ongoing verification that those controls are right and working. Hook: *diligence = "investigate", care = "act"*.

> **Real-world:** A hospital portal stays 100% online (availability ✓) but a coding bug lets patients view each other's lab results. That is a **confidentiality** and **privacy** failure, so uptime metrics don't help. The authorization check is the vulnerability, and the fix is a technical preventive control (object-level authorization), backed by detective logging.

EXAM TRAPS · DOMAIN 1

- Authentication ≠ authorization. MFA doesn't fix excessive permissions.
- Encryption protects confidentiality. It does nothing for availability.
- A detective control (IDS, camera) reports; it does not block.
- Security advises; the **business risk owner** accepts risk.
- When an answer protects human life/safety, it is almost always the BEST answer.

Domain 1 drill · 12 questions

Closed-book. Aim for 10/12+. Answers and reasoning on the next page.

1 A hospital's patient portal has 99.99% uptime, but a defect lets logged-in patients view other patients' lab results. Which security objective is MOST directly violated?

- **A.** Availability
- **B.** Non-repudiation
- **C.** Confidentiality
- **D.** Integrity

2 An employee types her username, then her password, and is then allowed read-only access to a shared folder. Which step is the read-only access?

- **A.** Authentication
- **B.** Identification
- **C.** Authorization
- **D.** Accounting

3 A company wants to prove that a specific manager approved a wire transfer and cannot later deny it. What BEST provides this?

- **A.** Encrypting the transfer with AES
- **B.** A daily backup of the approvals database
- **C.** A digital signature applied with the manager's private key
- **D.** A shared approvals mailbox

4 A security analyst finds a critical vulnerability. Patching would break a revenue system, and the business decides to keep running it unchanged for 90 days with written approval. Which risk treatment is this?

- **A.** Risk mitigation
- **B.** Risk acceptance
- **C.** Risk avoidance
- **D.** Risk transfer

5 Who should formally sign off on accepting the residual risk in the previous scenario?

- **A.** The business owner of the system or risk
- **B.** The external auditor
- **C.** The help desk manager
- **D.** The security analyst who found it

6 A warning banner stating 'Unauthorized access is prohibited and monitored' is primarily which control function?

- **A.** Compensating
- **B.** Corrective
- **C.** Detective
- **D.** Deterrent

7 A legacy system cannot support MFA, so the team adds strict IP allow-listing and extra log monitoring for it. These added measures are BEST described as:

A. Compensating controls
B. Corrective controls
C. Deterrent controls
D. Directive controls

---

8 Which document would contain the requirement 'All laptops must use AES-256 full-disk encryption'?

A. Procedure
B. Guideline
C. Policy
D. Standard

---

9 Your employer asks you to quietly ignore a safety-related vulnerability in a product used by hospitals to meet a release date. Under the ISC2 Code of Ethics, which consideration takes precedence?

A. Following your manager's direction
B. Protecting society, the common good and the infrastructure
C. Providing diligent service to your principal
D. Advancing and protecting the profession

---

10 A company performs annual reviews to verify that its encryption controls are still configured correctly and meet current requirements. This ongoing verification is an example of:

A. Due diligence
B. Due care
C. Risk transfer
D. Non-repudiation

---

11 A server worth $100,000 would lose 40% of its value in a flood, and floods are expected once every 10 years. What is the annualized loss expectancy (ALE)?

A. $400,000
B. $40,000
C. $10,000
D. $4,000

---

12 A marketing team collects customers' birth dates 'just in case' with no stated use. Which privacy principle is MOST directly violated?

A. Separation of duties
B. Data minimization / purpose limitation
C. Non-repudiation
D. Availability

Domain 1 drill · answers

1. C Confidentiality
Data was disclosed to unauthorized people. Uptime (availability) is fine and nothing was altered (integrity).

2. C Authorization
The username is identification, the password is authentication, and the granted permission is authorization.

3. C A digital signature applied with the manager's private key
Only the manager holds the private key, so a signature gives non-repudiation. A shared mailbox breaks accountability; encryption gives confidentiality only.

4. B Risk acceptance
A documented, approved decision to live with the risk is acceptance. Nothing was added, shifted, or stopped.

5. A The business owner of the system or risk
Risk acceptance is a management decision by the accountable risk owner. Security advises; auditors assess independently.

6. D Deterrent
It discourages wrongdoing but neither detects nor fixes anything. (It is also directive/administrative in type.)

7. A Compensating controls
Compensating controls provide alternative protection when the primary control isn't feasible.

8. D Standard
A specific, mandatory, measurable rule is a standard. The policy says data must be protected; the procedure says how to enable it.

9. B Protecting society, the common good and the infrastructure
Canon 1 (protect society) comes first, ahead of duty to principals (Canon 3). Canons are applied in order.

10. A Due diligence
Due diligence is the research/verification that controls are right and working; due care is implementing and operating them.

11. D $4,000
SLE = $100,000 × 0.40 = $40,000. ARO = 0.1. ALE = $40,000 × 0.1 = $4,000.

12. B Data minimization / purpose limitation
Privacy requires collecting only what is needed for a stated purpose, even if the data is kept confidential.

My score: ___ / 12 Date: _____ Re-test date: _____

DOMAIN 2

Security Governance

17.3% of exam

What the exam wants: How an organization directs, measures and sustains security: GRC, laws and frameworks, business continuity and disaster recovery, awareness programs, and metrics. Expect 'what should management do' questions.

GRC: governance, risk, compliance

- **Governance** sets direction, roles and accountability (board → senior management → CISO → staff). Senior management is ultimately accountable for security.
- **Risk management** prioritizes what to protect and how much to spend.
- **Compliance** proves obligations (laws, contracts, standards) are met, via audits and evidence. **Compliant ≠ secure.**
- **Governing emerging tech / AI:** inventory AI tools in use ("shadow AI"), set an acceptable-use policy, classify what data may go into AI services, assign owners.

Law / standard	Scope
GDPR	EU personal data of EU residents, wherever processed
HIPAA	US health information (PHI)
PCI DSS	Payment card data. An **industry standard enforced by contract**, not a law
SOX / GLBA	US public-company financial reporting / financial institutions' customer data
NIST CSF 2.0	Voluntary framework: **Govern, Identify, Protect, Detect, Respond, Recover**
ISO/IEC 27001 / 27002	International ISMS standard (certifiable) / control guidance

Business continuity, disaster recovery, BIA

- **BCP** keeps critical *business functions* running during disruption (people, process, alternate ways of working).
- **DRP** restores *IT systems and data* after disruption. DR is a subset of BC.
- **BIA** (business impact analysis) comes **first**: identifies critical processes, dependencies, outage impact, and sets recovery priorities.

Metric	Meaning	Hook
MTD (max tolerable downtime)	Longest outage before unrecoverable harm	The hard ceiling
RTO	Target time to restore the service (must be ≤ MTD)	**T** = **T**ime to restore
RPO	Max acceptable data loss, measured in time before the incident	**P** = **P**oint you roll back to

Recovery sites: Hot (fully equipped, live data; minutes–hours, most expensive) → **Warm** (hardware, needs data; hours–days) → **Cold** (space & power only; days–weeks, cheapest). Also cloud/mobile sites and reciprocal agreements.

Backup	Backs up	Restore needs
Full	Everything	Last full (fastest restore)
Incremental	Changes since last backup of any kind	Full + **every** incremental (fastest backup, slowest restore)
Differential	Changes since last full	Full + **latest** differential

3-2-1 rule: 3 copies, 2 media types, 1 offsite (ideally offline/immutable vs ransomware). **A backup is only proven by a successful restore test.**

Plan tests (least → most disruptive): checklist/read-through → tabletop/walkthrough → simulation → parallel (alternate site runs alongside production) → full interruption (production cut over, highest risk).

Redundancy: RAID, clustering, load balancers, UPS (short-term) + generator (long-term), dual ISPs, geographic separation.

Security awareness

Level	Goal	Example
Awareness	Change attention/behavior of everyone	Posters, phishing simulations, short videos
Training	Teach job-specific skills	Secure coding course for developers
Education	Deep understanding / career	Degree, certification

Topics: phishing & social engineering, password/passphrase hygiene and password managers, MFA fatigue, clean desk, tailgating, reporting incidents, safe AI use (don't paste confidential data into public AI tools; deepfake voice/video requests must be verified). Measure **behavior** (report rates, click rates), not just completion.

Measuring cybersecurity effectiveness

- **Metric**: any measurement (e.g., number of phishing reports).
- **KPI** (key performance indicator): how well a control/process performs. e.g. % critical patches applied within SLA, **MTTD** (mean time to detect), **MTTR** (mean time to respond/recover).
- **KRI** (key risk indicator): a *leading* signal that risk is rising. e.g. number of unpatched internet-facing systems, accounts without MFA.
- Report to leadership in **business terms** via dashboards; validate with audits (internal/external), assessments and control testing.

> A documented policy is not evidence a control works. Effectiveness is shown by testing, metrics and audit evidence.

Third parties and change governance

Vendor access must be **approved, named (no shared logins), MFA-protected, least-privilege, time-limited, logged and reviewed**. Contracts/SLAs define security obligations and right to audit. Emergency changes still need authorization, rollback, documentation and a **retrospective review**.

> **Real-world:** A regional bank's BIA shows online payments have an MTD of 8 hours. Leadership sets RTO = 4 h and RPO = 15 min. Nightly backups cannot meet a 15-minute RPO, so the team adds near-continuous replication to a warm site and proves it with a quarterly restore test, reported to the board as a KPI.

EXAM TRAPS · DOMAIN 2

- BC (business functions) ≠ DR (IT systems). BIA happens before either plan is written.
- RTO = time to restore; RPO = acceptable data loss. They are independent.
- Incremental: fast backup / slow restore. Differential: the reverse.
- PCI DSS is a contractual industry standard, not a law.
- Full-interruption tests are the most realistic *and* riskiest; never the 'first' test to run.

Domain 2 drill · 12 questions

Closed-book. Aim for 10/12+. Answers and reasoning on the next page.

1 Before writing recovery plans, a company needs to know which business processes are most critical and how long each can be down. What should it perform FIRST?

A. A business impact analysis (BIA)
B. A penetration test
C. A full-interruption test
D. A vulnerability scan

---

2 A payroll system must be running again within 6 hours and may lose no more than 30 minutes of data. Which statement is correct?

A. MTD = 30 minutes; RTO = 6 hours
B. RTO = 30 minutes; RPO = 6 hours
C. RPO = 6 hours; MTD = 30 minutes
D. RTO = 6 hours; RPO = 30 minutes

---

3 Backups run as a full backup Sunday and incrementals Monday through Friday. The server fails Friday afternoon after Friday's backup. What is needed to restore?

A. Sunday's full plus Friday's incremental only
B. Only Friday's incremental
C. Only Sunday's full backup
D. Sunday's full plus every incremental from Monday through Friday

---

4 Which recovery site offers the FASTEST recovery but at the highest cost?

A. Warm site
B. Hot site
C. Cold site
D. Reciprocal agreement

---

5 A team wants to test its DR plan for the first time with the least risk to production. Which test is MOST appropriate?

A. Live failover during peak hours
B. Full-interruption test
C. Tabletop (walkthrough) exercise
D. Parallel test

---

6 Backups report 'successful' every night for a year. What is the BEST evidence they will actually work during a disaster?

A. A documented, successful test restore
B. Vendor certification of the backup tool
C. Green status on the backup dashboard
D. An increase in backup storage usage

---

7 An online retailer in the US accepts credit cards from customers worldwide. Which requirement is an industry standard enforced by contract rather than a law?

A. PCI DSS
B. HIPAA
C. SOX
D. GDPR

---

8 The CISO wants an indicator that warns leadership risk is increasing BEFORE an incident happens. Which is the BEST example of a key risk indicator (KRI)?

A. Average time to resolve help-desk tickets
B. Number of incidents closed last quarter
C. Total security training hours delivered
D. Number of internet-facing systems missing critical patches

---

9 A company's phishing simulation click rate drops from 18% to 4% over a year and the report rate rises. What does this primarily measure?

A. Compliance with PCI DSS
B. Effectiveness of the security awareness program
C. Effectiveness of disaster recovery
D. Firewall rule accuracy

---

10 Which NIST Cybersecurity Framework 2.0 function was added to emphasize strategy, roles and oversight?

A. Protect
B. Govern
C. Identify
D. Recover

---

11 A critical zero-day patch must go out today, outside the normal change window. What is the BEST governance approach?

A. Wait for next month's change window
B. Deploy immediately with no documentation since it's urgent
C. Use the emergency change process with approval, a rollback plan and a post-change review
D. Let each server owner patch whenever convenient

---

12 A business owner says, 'We passed our compliance audit, so we are secure.' What is the BEST response?

A. Agree, since compliance and security are the same
B. Audits replace the need for risk assessments
C. Compliance shows obligations were met at a point in time; it does not prove security is effective against current threats
D. Compliance only matters for government agencies

Domain 2 drill · answers

1. A **A business impact analysis (BIA)**
The BIA identifies critical functions, dependencies and outage impacts, and drives RTO/RPO and priorities.

2. D **RTO = 6 hours; RPO = 30 minutes**
RTO is restoration time; RPO is acceptable data loss measured in time.

3. D **Sunday's full plus every incremental from Monday through Friday**
Incrementals capture changes since the last backup of any kind, so every one in the chain is required.

4. B **Hot site**
Hot sites are fully equipped with near-current data; cold sites provide only space and power.

5. C **Tabletop (walkthrough) exercise**
A tabletop walks through the plan in discussion form with no impact on systems. Full interruption is the riskiest.

6. A **A documented, successful test restore**
Only restoring data proves recoverability. Job success doesn't prove the data or keys are usable.

7. A **PCI DSS**
PCI DSS comes from the card brands and is enforced through merchant contracts. The others are laws.

8. D **Number of internet-facing systems missing critical patches**
KRIs are leading signals of rising risk. Closed incidents are lagging; the others measure activity, not risk.

9. B **Effectiveness of the security awareness program**
Behavior change (clicks down, reports up) is the right way to measure awareness, not just completion rates.

10. B **Govern**
CSF 2.0 (2024) added Govern to the existing Identify, Protect, Detect, Respond and Recover.

11. C **Use the emergency change process with approval, a rollback plan and a post-change review**
Emergency changes are faster, not ungoverned: still authorized, reversible, documented and reviewed.

12. C **Compliance shows obligations were met at a point in time; it does not prove security is effective against current threats**
Compliance is a minimum, point-in-time bar. Risk-based security and ongoing testing are still needed.

My score: ___ / 12 Date: _____ Re-test date: _____

DOMAIN 3

Identity & Access Management (IAM) Concepts

20% of exam

What the exam wants: Who gets access, how they prove it, how much they get, and how that changes over time. Watch for least privilege, separation of duties, MFA factor categories, access models and the joiner-mover-leaver lifecycle.

Authentication factors

Factor	Examples	Weakness
Something you **know**	Password, PIN, security question	Phished, guessed, reused
Something you **have**	Smart card, hardware key, authenticator app, phone	Lost/stolen; SMS can be SIM-swapped
Something you **are**	Fingerprint, face, iris	Can't be changed if compromised
(Context) somewhere you are / something you do	Geolocation, typing rhythm	Usually supporting signals

MFA = two or more different categories. Password + PIN = single-factor. Password + fingerprint = MFA. **Phishing-resistant MFA**: FIDO2 security keys / passkeys. Watch for **MFA fatigue** (push-bombing). Never approve a prompt you didn't start.

Biometric errors: FRR (false rejection, Type I, legitimate user denied, annoying); FAR (false acceptance, Type II, impostor let in, **dangerous**). CER/EER = where they're equal; lower CER = more accurate.

Logical access principles

- **Least privilege**: minimum permissions needed for the job, for the minimum time.
- **Need to know**: even with clearance, only access the information your task requires.
- **Separation (segregation) of duties**: split sensitive tasks so no single person can complete them alone (create vendor ≠ approve payment).
- **Two-person rule / dual control**: two people act together (e.g., opening the vault, root key ceremony).
- **Privilege creep**: permissions accumulate as people change roles. Cure: access reviews/recertification.
- **Just-in-time (JIT) / Privileged Access Management (PAM)**: admin rights granted temporarily, approved, recorded, then removed.

Access control models

Model	Who decides	Example	Hook
DAC	Resource **owner**	You share your file with a colleague	"Owner's Discretion"
MAC	System enforces **labels & clearances**	Military Top Secret / Secret	"Military"
RBAC	**Job role** / group	All tellers get the Teller role	"Role"
Rule-based	Global rules for everyone	Firewall ACL; no logins after 10 pm	"Rules for all"
ABAC	**Attributes** + context	Contractor + managed device + business hours + doc label	"Any attribute"

Identity lifecycle management

Role definition → Provisioning → Review → Deprovisioning.

- **Joiner**: approved request, identity proofing, role-based access on day one.
- **Mover**: add new access **and remove old access** (otherwise privilege creep).
- **Leaver**: disable promptly: accounts, sessions, VPN, API tokens, keys, badges, third-party/SaaS access. Involuntary terminations: disable **at or before** notification.
- **Periodic review**: managers recertify access; flag dormant, orphaned and privileged accounts.
- **Non-human identities**: service accounts, API keys, CI/CD tokens and **AI agents** need owners, least privilege, rotation and logging like any user.

Frameworks and tools

Term	What it is
IdP	Identity provider that authenticates users (e.g., Entra ID, Okta)
SSO	One login → many apps. Convenience; does **not** grant authorization to everything. Single point of failure, so protect it with strong MFA.
Federation	Trust between separate organizations/domains so identities work across them
SAML	XML-based federation/SSO, common for enterprise web apps
OAuth 2.0	**Authorization** (delegated access via tokens)
OpenID Connect	**Authentication** layer on top of OAuth 2.0
Password vault / PAM	Stores, rotates and checks out privileged credentials with session recording

Physical access (supports logical access)

Badges, turnstiles, **mantraps** (prevent tailgating), guards, visitor logs and escorts, locks, CCTV, bollards, lighting. **Tailgating/piggybacking** = following an authorized person through a door. Combine physical and logical (badge required to unlock workstation room *and* MFA at login).

Real-world: An employee moves from Accounts Payable to Treasury. IT adds Treasury access but nobody removes AP access, so she can now create a vendor *and* release a wire. That is privilege creep breaking separation of duties. Fixes: mover workflow removes old roles, quarterly access recertification, and a SoD rule in the ERP system that blocks the toxic combination.

EXAM TRAPS · DOMAIN 3

- Password + PIN (or password + security question) is NOT MFA.
- SSO ≠ access to everything; authorization still applies per app.
- OAuth = authorization; OpenID Connect = authentication.
- Shared accounts kill accountability and non-repudiation.
- FAR is the security-relevant biometric error (impostor accepted).

Domain 3 drill · 12 questions

Closed-book. Aim for 10/12+. Answers and reasoning on the next page.

1 Which combination provides true multifactor authentication?

A. Two different passwords
B. Password and a PIN
C. Password and a fingerprint scan
D. Password and a security question

---

2 A user receives 20 push MFA prompts at midnight that she didn't initiate. What should she do?

A. Deny the prompts and report it to security immediately
B. Ignore them and report it next week
C. Turn off MFA on her account
D. Approve one so the prompts stop

---

3 Which biometric error rate is MOST concerning from a security perspective?

A. False acceptance rate (FAR)
B. Crossover error rate (CER)
C. False rejection rate (FRR)
D. Enrollment time

---

4 A government agency labels documents Secret and Top Secret and only users with matching clearance can open them; users cannot change this. Which model is this?

A. Role-based access control (RBAC)
B. Rule-based access control
C. Mandatory access control (MAC)
D. Discretionary access control (DAC)

---

5 A company wants contractors to open only Internal-labeled files, only from company-managed laptops, and only between 8 a.m. and 6 p.m. Which model BEST fits?

A. Mandatory access control (MAC)
B. Role-based access control (RBAC) alone
C. Attribute-based access control (ABAC)
D. Discretionary access control (DAC)

---

6 A developer shares a project folder with a teammate directly through the file's sharing settings. Which model is in use?

A. Mandatory access control (MAC)
B. Discretionary access control (DAC)
C. Attribute-based access control (ABAC)
D. Rule-based access control

---

7 An accountant can both create new vendors and approve payments to them. Which principle is MOST directly violated?

A. Non-repudiation
B. Separation of duties
C. Defense in depth
D. Need to know

---

8 An employee has moved through four departments in five years and still holds access from all of them. What is this called and how is it BEST fixed?

A. Privilege creep; regular access reviews and removing old access on role change
B. Least privilege; grant more access
C. Separation of duties; merge roles
D. Federation; add SSO

---

9 An administrator is terminated for misconduct. When should their access be disabled?

A. After HR finishes the exit paperwork
B. At or before the time they are notified of the termination
C. Within 30 days per the retention policy
D. At the end of their last week

---

10 An employee logs in once to the company portal and can then open email, HR and expense apps without logging in again. What is this?

A. Separation of duties
B. Mandatory access control
C. Multifactor authentication
D. Single sign-on (SSO)

---

11 A mobile app lets users grant it access to their calendar on another service without sharing their password. Which protocol is designed for this delegated authorization?

A. SAML
B. LDAP
C. OpenID Connect
D. OAuth 2.0

---

12 A team deploys an AI agent that reads tickets and can run scripts in production. What is the BEST identity control for this agent?

A. Reuse an existing administrator account so it never hits permission errors
B. A shared team account so anyone can check its work
C. No identity, since it is software rather than a person
D. A dedicated, least-privilege identity with logging and human approval for high-impact actions

---

Domain 3 drill · answers

1. C Password and a fingerprint scan
MFA needs different categories: knowledge plus inherence. The other options are all 'something you know'.

2. A Deny the prompts and report it to security immediately
This is MFA fatigue; her password is likely compromised. Deny, report, and reset the password.

3. A False acceptance rate (FAR)
FAR means impostors are let in (Type II). FRR mostly annoys legitimate users.

4. C Mandatory access control (MAC)
MAC is centrally enforced labels and clearances; owners have no discretion.

5. C Attribute-based access control (ABAC)
ABAC combines user, resource, device and time attributes. RBAC alone can't easily express context.

6. B Discretionary access control (DAC)
The resource owner decides who gets access: that's DAC.

7. B Separation of duties
One person can complete an entire sensitive transaction, which enables fraud. Split the duties.

8. A Privilege creep; regular access reviews and removing old access on role change
Mover processes must remove old access, and periodic recertification catches what slips through.

9. B At or before the time they are notified of the termination
Hostile-termination risk is highest at notification, so revoke access at the same time or before.

10. D Single sign-on (SSO)
SSO is one authentication for many apps. Each app still enforces its own authorization.

11. D OAuth 2.0
OAuth 2.0 issues tokens for delegated authorization. OpenID Connect adds authentication on top.

12. D A dedicated, least-privilege identity with logging and human approval for high-impact actions
Non-human identities need their own scoped credentials, logging and oversight, just like users.

My score: ___ / 12 Date: _____ Re-test date: _____

DOMAIN 4

Networking & Cloud Security Concepts

21.3% of exam

What the exam wants: Enough networking to reason about where attacks happen and which control stops them, plus segmentation, Zero Trust, wireless/IoT and cloud shared responsibility. You need to recognize concepts, not configure devices.

OSI and TCP/IP models

#	OSI layer	Data unit	Examples / devices	TCP/IP
7	Application	Data	HTTP, DNS, SMTP, FTP	Application
6	Presentation		Encoding, encryption formats (TLS often placed here/5)	
5	Session		Session setup/teardown	
4	Transport	Segment	TCP, UDP, ports	Transport
3	Network	Packet	IP, ICMP, **routers**	Internet
2	Data Link	Frame	MAC, ARP, **switches**, VLANs	Network access (link)
1	Physical	Bits	Cables, hubs, radio	

Mnemonic (1→7): **P**lease **D**o **N**ot **T**hrow **S**ausage **P**izza **A**way. TCP 3-way handshake: **SYN → SYN-ACK → ACK**. TCP = reliable, ordered, connection-oriented; UDP = fast, connectionless (DNS queries, VoIP, streaming).

IP addressing

- **IPv4**: 32-bit, dotted decimal (192.168.1.10). **IPv6**: 128-bit hex (2001:db8::1), huge address space, IPsec built into the design.
- **Private IPv4 ranges** (RFC 1918): 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16. Not routable on the internet; **NAT** translates to public addresses.
- Loopback: 127.0.0.1 (IPv4), ::1 (IPv6). **DHCP** assigns IP settings automatically; **DNS** resolves names to IPs; **ARP** maps IP → MAC on a LAN.

Ports to memorize

Port	Service	Port	Service
20/21	FTP (cleartext)	**143**	IMAP
22	SSH / SFTP / SCP	**161/162**	SNMP
23	Telnet (cleartext, avoid)	**389 / 636**	LDAP / LDAPS
25	SMTP	**443**	HTTPS
53	DNS (UDP & TCP)	**445**	SMB (file sharing)
67/68	DHCP	**587 / 465**	SMTP submission (TLS)
80	HTTP	**993 / 995**	IMAPS / POP3S
110	POP3	**1433**	Microsoft SQL Server
123	NTP (time sync)	**3389**	RDP

Insecure → secure: Telnet→SSH, FTP→SFTP/FTPS, HTTP→HTTPS, LDAP→LDAPS, SNMPv1/2→SNMPv3, POP3/IMAP→POP3S/IMAPS. Well-known = 0–1023, registered = 1024–49151, dynamic = 49152–65535. A port number is a convention, not proof traffic is safe.

Attacks you must recognize

Attack	What happens	Primary defense
DoS / DDoS	Overwhelm a resource (availability)	Rate limiting, scrubbing/CDN, redundancy
On-path (MITM)	Intercept/alter traffic between two parties	TLS/encryption, certificate validation
Spoofing	Fake source IP/MAC/email/caller ID	Filtering, authentication (SPF/DKIM/DMARC for email)
DNS poisoning	False DNS answers redirect users	DNSSEC, trusted resolvers
SQL injection	Malicious input runs database commands	Parameterized queries, input validation
Cross-site scripting (XSS)	Injected script runs in victims' browsers	Output encoding, input validation
Buffer overflow	Input exceeds memory bounds; code execution	Bounds checking, patching
Password attacks	Brute force, dictionary, credential stuffing (reused leaked creds), spraying (one common password, many accounts)	MFA, lockout, unique passwords, salted hashes

Malware: virus (attaches to a host file, needs user action) · **worm** (self-propagates, no user action) · trojan (disguised as legitimate) · ransomware (encrypts/extorts) · rootkit (hides deep, often kernel) · spyware/keylogger · logic bomb (triggers on a condition) · botnet (remotely controlled zombies) · fileless (lives in memory).

Network defenses and architecture

Control	Does
Packet-filter firewall	Stateless; allows/denies by IP, port, protocol
Stateful firewall	Tracks connections; allows return traffic of approved sessions
NGFW / app-layer proxy	Inspects applications/content, user identity, IPS features
WAF	Protects web apps from SQLi, XSS, etc.
IDS / IPS	IDS **detects & alerts** (passive); IPS sits inline and **blocks**. Signature-based (known) vs anomaly/behavior-based (unknown, more false positives)
HIDS / NIDS	Host-based vs network-based
VPN	Encrypted tunnel over untrusted network (IPsec, TLS); site-to-site or remote access
NAC	Checks device identity/health (posture) before granting network access
EDR	Endpoint detection & response: monitors and contains threats on hosts

- **Implicit deny**: anything not explicitly allowed is blocked (last firewall rule).
- **DMZ / screened subnet**: public-facing servers isolated between the internet and the internal network.

- **Segmentation**: firewall zones, **VLANs** (logical separation at Layer 2), **micro-segmentation** (per-workload policies) → limit lateral movement.
- **Zero Trust**: "never trust, always verify." No implicit trust from network location; verify identity, device and context for *every* request; least privilege; assume breach. A policy decision point evaluates, and a policy enforcement point allows/blocks.

Wireless, embedded systems and IoT

- **WEP** (broken, never use) → WPA (TKIP, deprecated) → **WPA2** (AES-CCMP) → **WPA3** (SAE, strongest). Enterprise mode uses 802.1X/RADIUS per-user authentication.
- Wireless threats: **rogue AP** (unauthorized AP on your network), **evil twin** (fake AP mimicking yours), jamming, war driving.
- **IoT/embedded** (cameras, sensors, medical devices, OT/SCADA): default passwords, weak or no patching, long lifespans. Controls: change defaults, inventory, **isolate on a separate VLAN/segment**, monitor, update firmware.

Cloud security

NIST cloud characteristics: on-demand self-service · broad network access · resource pooling (multi-tenancy) · rapid elasticity · measured service (pay per use).

Service model	Provider manages	Customer manages	Example
IaaS	Hardware, network, hypervisor	OS, patches, apps, data, IAM, config	Virtual machines
PaaS	+ OS and runtime	Apps, data, IAM, config	Managed app platform/database
SaaS	Almost everything	**Data, users, access, settings**	Email, CRM

Deployment models: public (shared, multi-tenant) · private (one organization) · community (orgs with shared needs) · hybrid (mix). **Shared responsibility:** the customer is **always** responsible for its data and who can access it. Most cloud breaches are customer misconfigurations (public buckets, over-permissive IAM). Use an **SLA** to define uptime and support, and an **MSP/MSSP** for outsourced management/security.

Virtualization: hypervisor isolates VMs (Type 1 bare-metal, Type 2 hosted). **Containers** share the host kernel, so protect images, secrets and runtime permissions. (Deep Kubernetes is out of scope.)

> **Real-world:** Attackers phish one retail employee, land on a laptop, and because the network is flat they reach the payment-card servers directly. Segmentation (PCI zone behind an internal firewall), Zero Trust access checks and EDR would each have broken the chain. This is why 'lateral movement' questions usually point to **segmentation**.

EXAM TRAPS · DOMAIN 4

- IDS detects/alerts; IPS blocks. A firewall filters by rules; it is not an IDS.
- Being 'inside' the network grants no trust under Zero Trust.
- In every cloud model the customer owns its data and access decisions.
- VLANs separate traffic logically; they are not encryption.
- Worm = no user action needed; virus = needs a host and user action.

Domain 4 drill · 12 questions

Closed-book. Aim for 10/12+. Answers and reasoning on the next page.

1 At which OSI layer do routers make forwarding decisions using IP addresses?

A. Layer 3 – Network
B. Layer 4 – Transport
C. Layer 7 – Application
D. Layer 2 – Data Link

2 Users can reach an internal web server by its IP address but not by its name. Which service should be investigated FIRST?

A. SMTP
B. NTP
C. DNS
D. DHCP

3 An administrator still manages switches over Telnet. What is the BEST replacement and why?

A. SNMPv1 on port 161, because it is standard
B. SSH on port 22, because it encrypts the session including credentials
C. FTP on port 21, because it is faster
D. HTTP on port 80, because browsers support it

4 Which statement about IDS and IPS is correct?

A. An IPS sits inline and can block traffic; an IDS detects and alerts
B. An IPS replaces the need for a firewall
C. Both only work on encrypted traffic
D. An IDS blocks traffic; an IPS only logs it

5 An attacker compromises one workstation and then scans and reaches servers in other departments. Which control MOST directly limits this?

A. Full-disk encryption
B. Network segmentation
C. Longer passwords
D. Daily backups

6 Which statement BEST describes Zero Trust?

A. Only external traffic needs authentication
B. Devices on the internal network are trusted by default
C. A single perimeter firewall is sufficient
D. Every access request is verified based on identity, device and context, regardless of network location

7 A company's web servers must be reachable from the internet while keeping the internal network protected. Where should they be placed?

A. On the internal user VLAN
B. On the same subnet as the database servers
C. Directly on the internet with no firewall
D. In a DMZ (screened subnet)

---

8 Smart cameras in a warehouse use default passwords and cannot be patched quickly. What is the BEST control?

A. Connect them to the guest Wi-Fi
B. Change default credentials and isolate the cameras on a separate network segment
C. Leave them on the main network so they can be monitored
D. Disable the firewall for them so updates work

---

9 An attacker sets up a wireless access point with the same name as the coffee shop's network to capture users' traffic. What is this?

A. Rogue access point
B. MAC flooding
C. Evil twin
D. War driving

---

10 A company uses a cloud provider's virtual machines (IaaS). Who is typically responsible for patching the guest operating system?

A. The internet service provider
B. The cloud provider
C. The customer
D. The hardware manufacturer

---

11 A SaaS CRM's data is exposed because an employee set a report to 'public link – anyone'. Who is responsible?

A. The employee's internet provider
B. The SaaS provider, because it hosts the app
C. Nobody, since SaaS providers handle all security
D. The customer organization, which owns its data, users and sharing settings

---

12 Malware spreads across a network on its own by exploiting a vulnerability, with no user clicking anything. What type is it?

A. Worm
B. Trojan
C. Virus
D. Logic bomb

Domain 4 drill · answers

1. A **Layer 3 – Network**
Routers work with IP at Layer 3; switches use MAC addresses at Layer 2.

2. C **DNS**
DNS resolves names to IPs. Since the IP works, the network path is fine.

3. B **SSH on port 22, because it encrypts the session including credentials**
Telnet sends everything, including passwords, in cleartext. SSH encrypts.

4. A **An IPS sits inline and can block traffic; an IDS detects and alerts**
IDS is passive detection; IPS is active prevention in the traffic path.

5. B **Network segmentation**
Segmentation (zones, VLANs, micro-segmentation) restricts lateral movement between network areas.

6. D **Every access request is verified based on identity, device and context, regardless of network location**
Zero Trust removes implicit trust from location: never trust, always verify, least privilege.

7. D **In a DMZ (screened subnet)**
A DMZ isolates public-facing services so a compromise doesn't give direct access to the internal network.

8. B **Change default credentials and isolate the cameras on a separate network segment**
IoT devices are weak and hard to patch, so isolate them to limit what an attacker can reach.

9. C **Evil twin**
An evil twin impersonates a legitimate network. A rogue AP is an unauthorized AP attached to your network.

10. C **The customer**
In IaaS the provider secures hardware and hypervisor; the customer manages the OS and up.

11. D **The customer organization, which owns its data, users and sharing settings**
In every cloud model, the customer is accountable for its data and access configuration.

12. A **Worm**
Worms self-propagate. Viruses need a host file and user action; trojans need to be run by a user.

My score: ___ / 12 Date: _____ Re-test date: _____

DOMAIN 5 Security Operations & Incident Response 17.3% of exam

What the exam wants: Day-to-day protection: data handling, cryptography, logging and triage, threat intelligence, incident response, asset/configuration/change management and security testing. Sequencing ('what FIRST?') questions live here.

Data handling lifecycle

Create → Store → Use → Share → Archive → Destroy. The **data owner** (business) classifies and is accountable; the **data custodian** (IT) implements protection day-to-day.

- **Classification** (e.g., Public, Internal, Confidential, Restricted) → **labeling** (marking so handlers know) → handling rules.
- **Masking** hides part of the data (****-1234); **tokenization** swaps it for a meaningless token; **anonymization** removes identity irreversibly.
- **Retention**: keep only as long as policy/law requires, then dispose securely. **DLP** detects/blocks sensitive data leaving.
- Data states: **at rest** (disk encryption), **in transit** (TLS/VPN), **in use** (access control, memory protection).

Sanitization (NIST 800-88)	Method	When
Clear	Overwrite with standard tools	Reuse inside the organization
Purge	Degauss (magnetic only), crypto-erase, secure erase	Media leaving your control
Destroy	Shred, pulverize, incinerate	Highest sensitivity / end of life

> Deleting a file or quick-formatting does **not** sanitize. Degaussing does not work on SSDs.

Cryptography essentials

	Symmetric	Asymmetric	Hashing
Keys	One shared secret	Public + private pair	No key; one-way
Speed	Fast (bulk data)	Slow	Fast
Examples	AES	RSA, ECC, Diffie-Hellman	SHA-256, SHA-3
Provides	Confidentiality	Confidentiality, key exchange, signatures	Integrity
Challenge	Key distribution; n(n-1)/2 keys	Performance	Collisions (avoid MD5/SHA-1)

- **Encrypt for someone** → use the **recipient's public key**; only their private key decrypts.
- **Digital signature** → hash the message, sign with the **sender's private key**; anyone verifies with the sender's public key → integrity + authenticity + non-repudiation (not confidentiality).
- **Certificates/PKI**: a Certificate Authority binds an identity to a public key. TLS (HTTPS) uses asymmetric crypto to exchange a symmetric session key.
- **Salting** passwords before hashing defeats rainbow tables. Passwords should be hashed, never encrypted or stored in clear.
- **Quantum-resistant (post-quantum) cryptography**: future quantum computers threaten RSA/ECC. NIST published PQC standards (FIPS 203/204/205, 2024). "Harvest now, decrypt later" means long-lived secrets

need planning now; symmetric crypto survives with larger keys (AES-256). Know the concept and why **crypto-agility** (ability to swap algorithms) matters.

Logging, monitoring, event triage

- **Event** = any observable occurrence. **Incident** = an event that actually harms or threatens CIA/policy. **Breach** = confirmed disclosure of data.
- **SIEM** aggregates, normalizes and **correlates** logs; **SOAR** automates response playbooks. A **SOC** monitors 24×7.
- Protect logs: centralized, access-controlled, tamper-evident, **time-synchronized (NTP)**, retained per policy.
- Triage outcomes: **true positive** (real attack flagged) · **false positive** (benign flagged, causes alert fatigue) · **false negative** (real attack missed, **most dangerous**) · true negative.
- **Baseline** normal behavior so anomalies stand out.

Threat actors and threat intelligence

Actor	Motive / capability
Nation-state / APT	Espionage, sabotage; highest resources, persistent
Organized crime	Money: ransomware, fraud
Hacktivist	Ideology: defacement, leaks, DDoS
Insider (malicious or negligent)	Already has access; hardest to detect
Script kiddie	Low skill, uses existing tools

Threat intelligence: strategic (executives, trends), operational (campaigns), tactical (TTPs, **IOCs** like malicious IPs/hashes). Sources: ISACs, vendors, government (CISA), OSINT. **Frameworks: MITRE ATT&CK** (catalog of adversary tactics & techniques) · **Cyber Kill Chain** (Recon → Weaponize → Deliver → Exploit → Install → Command & Control → Actions on objectives) · **STRIDE** (threat modeling).

AI-era threats: AI-written phishing, deepfake voice/video for payment fraud, **prompt injection** (untrusted text hijacks an AI's instructions), **data poisoning** (corrupting training data), sensitive data leakage into AI tools, over-privileged AI agents. Defenses are classic: verify through a trusted channel, least privilege, human approval for high-impact actions, logging.

Incident response

1 Preparation | 2 Detection & Analysis | 3 Containment | 4 Eradication | 5 Recovery | 6 Lessons Learned

- **Preparation** comes first: IR plan, team (CSIRT), roles, contacts, tools, training, **exercises (tabletops)**.
- **Detection & analysis**: validate, scope, prioritize, notify per plan.
- **Containment** stops the spread (isolate host, disable account) **while preserving evidence**. Short-term then long-term.
- **Eradication** removes the root cause (malware, attacker accounts, vulnerability). **Recovery** restores from clean sources and monitors.
- **Lessons learned**: what happened, what to improve; update plan and controls.

Evidence: order of volatility (collect memory/RAM before disk); work on **forensic copies**, verify with **hashes**; document every hand-off in the **chain of custody**. Communicate only through approved channels (legal, PR, regulators per plan).

> NIST SP 800-61 groups phases slightly differently (Containment, Eradication & Recovery as one), and Rev. 3 (2025) maps to CSF 2.0 functions. The **order** is what the exam tests.

Asset, configuration and change management

- **Asset lifecycle**: plan/acquire → deploy → operate/maintain → retire → **secure disposal**. You can't protect what you don't know you have, so **inventory comes first**.
- **Configuration management**: approved secure **baselines**, hardening (disable unused services/ports, change defaults; e.g. CIS Benchmarks), detect drift.
- **Patch management**: identify → test → approve → deploy → verify; prioritize by risk.
- **Change management**: request → impact/risk analysis → approval (Change Advisory Board) → test → implement with **rollback plan** → document → review.

Security testing

Term	Meaning
Vulnerability scan	Automated search for *potential* known weaknesses; doesn't exploit
Penetration test	**Authorized**, scoped attempt to exploit; needs written permission (rules of engagement)
Red / Blue / Purple team	Red attacks · Blue defends · **Purple** = both collaborating to improve detection (White team referees)
SAST / DAST	Static (source code, not running) / Dynamic (running application)
Fuzzing	Sending random/malformed input to find crashes
Physical pen test	Authorized attempts to tailgate, pick locks, plant devices
Black / gray / white box	Tester has no / partial / full knowledge of the target

Real-world: At 2 a.m. the SIEM correlates a VPN login from abroad with mass file renames on a file server. The on-call analyst follows the ransomware playbook: escalates to the IR lead, isolates the server from the network (doesn't power it off, so memory evidence survives), disables the compromised account, captures images with hashes and chain-of-custody forms, then eradicates and restores from an offline backup. Two weeks later, a lessons-learned review adds phishing-resistant MFA to VPN.

EXAM TRAPS · DOMAIN 5

- Containment (stop spread) ≠ eradication (remove cause) ≠ recovery (restore).
- Don't reboot or wipe first. Evidence and volatile memory matter.
- Hashing is one-way integrity, not encryption.
- Signatures use the sender's **private** key; encryption for a recipient uses their **public** key.
- A scan finding is not proof of exploitability; a pen test needs written authorization.

Domain 5 drill · 12 questions

Closed-book. Aim for 10/12+. Answers and reasoning on the next page.

1 A hard drive containing confidential data is being sold to an outside recycler. Which sanitization approach is MOST appropriate?

- **A.** Rename the folders
- **B.** Delete the files and empty the recycle bin
- **C.** Perform a quick format
- **D.** Purge or physically destroy the drive

2 Alice wants to send Bob a file that only Bob can read. Which key should she use to encrypt it?

- **A.** Alice's public key
- **B.** Bob's private key
- **C.** Alice's private key
- **D.** Bob's public key

3 Which is the BEST way to store user passwords in a database?

- **A.** Salted cryptographic hashes
- **B.** AES encryption with the key stored in the same database
- **C.** Plaintext in a restricted table
- **D.** Base64 encoding

4 A SIEM alert fires on suspicious activity, but investigation shows it was a scheduled admin job. What is this?

- **A.** True negative
- **B.** True positive
- **C.** False positive
- **D.** False negative

5 Logs from several servers show events in an impossible order, making an investigation unreliable. What MOST likely needs to be fixed?

- **A.** Disk encryption
- **B.** DHCP lease times
- **C.** Time synchronization (NTP) across systems
- **D.** VLAN configuration

6 A help-desk analyst confirms a workstation is infected with ransomware that is spreading. What should be done FIRST according to most IR plans?

- **A.** Isolate the workstation from the network per the IR plan and escalate
- **B.** Reimage the workstation immediately
- **C.** Post a warning on social media
- **D.** Pay the ransom to restore files quickly

7 Which phase of incident response should occur BEFORE any incident happens?

A. Eradication
B. Containment
C. Preparation
D. Lessons learned

---

8 Investigators collect a laptop's hard drive as evidence. What BEST supports its admissibility in court?

A. A documented chain of custody and hash values verifying the forensic image
B. Letting several staff examine it informally
C. Analyzing the original drive directly to save time
D. Keeping it in an unlocked shared office

---

9 A team simulates attacker techniques while the defenders tune detections together in real time. What is this called?

A. Red teaming
B. Purple teaming
C. Blue teaming
D. Black-box testing

---

10 What distinguishes a penetration test from a vulnerability scan?

A. A penetration test needs no permission
B. A vulnerability scan exploits every finding
C. They are identical activities
D. A penetration test attempts authorized exploitation within an agreed scope

---

11 An organization cannot locate several servers during an incident and doesn't know who owns them. Which practice was MOST lacking?

A. Risk transfer
B. Asset inventory and management
C. Purple teaming
D. Data masking

---

12 An executive gets a phone call in the CFO's cloned voice urgently requesting a wire transfer. What is the BEST response?

A. Reply to the caller's number to confirm
B. Verify the request through a known, separate channel before acting
C. Process it immediately because the voice matched
D. Ask the caller a personal question and proceed if answered

---

Domain 5 drill · answers

1. D Purge or physically destroy the drive
Media leaving your control needs purge (e.g., crypto-erase) or destruction. Delete/format leave recoverable data.

2. D Bob's public key
Encrypt with the recipient's public key; only the recipient's private key can decrypt.

3. A Salted cryptographic hashes
Hashing is one-way; salting defeats rainbow tables. Encoding isn't security; encryption is reversible.

4. C False positive
Benign activity flagged as malicious is a false positive. A missed real attack is a false negative (more dangerous).

5. C Time synchronization (NTP) across systems
Correlating events requires consistent timestamps from synchronized clocks.

6. A Isolate the workstation from the network per the IR plan and escalate
Containment limits spread while preserving evidence. Reimaging first destroys evidence and skips analysis.

7. C Preparation
Preparation (plan, team, tools, training, tabletop exercises) is the foundation for every other phase.

8. A A documented chain of custody and hash values verifying the forensic image
Chain of custody plus hash verification proves the evidence wasn't altered.

9. B Purple teaming
Purple = red and blue collaborating to improve detection and response.

10. D A penetration test attempts authorized exploitation within an agreed scope
Scans find potential weaknesses; pen tests prove exploitability with written authorization.

11. B Asset inventory and management
You can't protect, patch or respond to what you don't know you have.

12. B Verify the request through a known, separate channel before acting
Deepfakes defeat recognition. Out-of-band verification through a trusted channel is the control.

My score: ___ / 12 Date: _____ Re-test date: _____

Must-know contrasts (30)

Most wrong answers on the CC are the look-alike term. Cover the right column and recite it.

Threat vs vulnerability	Potential cause of harm vs exploitable weakness
Identification vs authentication	Claiming an identity vs proving it
Authentication vs authorization	Who you are vs what you may do
Due care vs due diligence	Doing the reasonable thing vs verifying it's right and working
Inherent vs residual risk	Before controls vs after controls
Risk appetite vs tolerance	Overall amount accepted vs acceptable variation
Policy / standard / procedure / guideline	Intent / mandatory specific rule / steps / optional advice
BC vs DR	Keep business functions going vs restore IT and data
RTO vs RPO vs MTD	Time to restore vs data loss allowed vs absolute max downtime
Incremental vs differential	Since last backup (all needed) vs since last full (latest needed)
KPI vs KRI	How well a process performs vs early warning of rising risk
DAC / MAC / RBAC / ABAC	Owner / labels & clearance / job role / attributes & context
Least privilege vs need to know	Minimum permissions vs minimum information
FAR vs FRR	Impostor accepted (Type II, dangerous) vs valid user rejected (Type I)
OAuth vs OpenID Connect vs SAML	Authorization vs authentication on OAuth vs XML-based enterprise SSO
TCP vs UDP	Reliable connection-oriented vs fast connectionless
IDS vs IPS	Detect & alert vs inline block
Virus vs worm vs trojan	Needs host + user vs self-spreads vs disguised as legit
Rogue AP vs evil twin	Unauthorized AP on your network vs fake AP impersonating yours
IaaS vs PaaS vs SaaS	Customer runs OS+ vs app+data vs data+users
Symmetric vs asymmetric	One shared key (fast) vs public/private pair (slow, key exchange)
Hashing vs encryption	One-way integrity vs reversible confidentiality
Encrypt vs sign	Recipient's public key vs sender's private key
Event vs incident vs breach	Anything observed vs harmful event vs confirmed data disclosure
False positive vs false negative	Benign flagged vs real attack missed (worse)
Containment vs eradication vs recovery	Stop spread vs remove cause vs restore service
Clear vs purge vs destroy	Overwrite for reuse vs degauss/crypto-erase vs shred
Vulnerability scan vs pen test	Finds potential weaknesses vs authorized exploitation
Red vs blue vs purple	Attack vs defend vs collaborate
SAST vs DAST	Code not running vs running application

Mock exam · 50 questions · 60 minutes

Simulate the real thing: timer on, no notes, **no going back** to change an answer. Weighted like the 2026 outline (D1 12 · D2 9 · D3 10 · D4 11 · D5 8). Target: **40+ (80%)**.

1 A firewall rule blocks all users from accessing the payroll system on weekends. Which model is this?

A. Rule-based access control
B. Discretionary access control
C. Mandatory access control
D. Role-based access control

2 A web form lets an attacker type ' OR 1=1 -- and see every customer record. What is the BEST fix?

A. Change the port from 443 to 8443
B. Enable a DHCP reservation
C. Use parameterized queries and validate input
D. Add more RAM to the database server

3 Which recovery site has power and space but no installed equipment or data?

A. Hot site
B. Mirrored site
C. Warm site
D. Cold site

4 Which protocol provides reliable, ordered delivery using a three-way handshake?

A. TCP
B. ICMP
C. UDP
D. ARP

5 Which BEST supports accountability for actions taken on a server?

A. A single password known by the whole team
B. A shared administrator account
C. Unique user accounts with protected audit logs
D. Disabling logs to save storage

6 What is the PRIMARY purpose of change management?

A. Ensure changes are reviewed, approved, tested and reversible to reduce risk
B. Eliminate the need for backups
C. Speed up deployments by skipping testing
D. Replace incident response

7 A company implements firewalls, endpoint protection, security training and locked server rooms. What concept is this?

A. Separation of duties
B. Defense in depth
C. Risk avoidance
D. Single point of failure

---

8 A US hospital is primarily regulated for patient data privacy under which law?

A. HIPAA
B. SOX
C. PCI DSS
D. GDPR

---

9 Admins receive elevated rights only when they request them for a specific task, and the rights expire after two hours. What is this?

A. Just-in-time privileged access
B. Single sign-on
C. Privilege creep
D. Discretionary access control

---

10 Which physical control is BEST at preventing tailgating into a data center?

A. A security camera
B. A 'No Tailgating' poster
C. A visitor sign-in sheet
D. A mantrap (access control vestibule)

---

11 Which cryptographic approach BEST protects a large database at rest efficiently?

A. Base64 encoding
B. Symmetric encryption such as AES
C. Asymmetric encryption such as RSA for all data
D. Hashing with SHA-256

---

12 Which firewall rule should be the LAST rule in a well-designed rule set?

A. Allow all traffic
B. Allow all internal traffic
C. Deny all traffic not explicitly allowed
D. Allow ICMP from anywhere

---

13 What is the MAIN security risk of single sign-on?

A. It eliminates logging
B. A compromised SSO credential can unlock many applications
C. Users must remember more passwords
D. It prevents MFA

---

14 When two ISC2 Code of Ethics canons conflict, which one takes precedence?

A. Provide diligent and competent service to principals
B. Whichever your employer chooses
C. Protect society, the common good, necessary public trust and confidence, and the infrastructure
D. Advance and protect the profession

---

15 A ransomware attack encrypts a company's file server so staff cannot open documents. Which objective is MOST directly affected?

A. Privacy
B. Availability
C. Non-repudiation
D. Confidentiality

---

16 During incident response, the malware has been removed and systems patched. What comes NEXT?

A. Recovery: restore systems from clean sources and monitor
B. Detection and analysis
C. Preparation
D. Containment

---

17 Which DR test runs the alternate site's systems at the same time as production, without stopping production?

A. Parallel test
B. Tabletop exercise
C. Checklist review
D. Full-interruption test

---

18 What is the PRIMARY goal of a business continuity plan?

A. Detect intrusions on the network
B. Restore IT systems after a disaster
C. Classify sensitive data
D. Keep critical business functions operating during a disruption

---

19 A smart card plus a PIN is an example of which factors?

A. Something you have and something you know
B. Two possession factors
C. Something you are and something you know
D. Two knowledge factors

---

20 Showing only the last four digits of a card number on a receipt is an example of:

A. Hashing
B. Asymmetric encryption
C. Data masking
D. Degaussing

---

21 What should be collected FIRST from a running compromised system?

A. Printed documentation
B. Archived backup tapes
C. Contents of memory (RAM)
D. The hard drive after shutdown

---

22 Which MFA method is MOST resistant to phishing?

A. Security questions
B. Email one-time code
C. SMS one-time code
D. FIDO2 hardware security key or passkey

---

23 A tester scans an application's source code for flaws without running it. What is this?

A. Fuzzing
B. Physical penetration testing
C. Dynamic application security testing (DAST)
D. Static application security testing (SAST)

---

24 Which document provides recommended, non-mandatory advice?

A. Standard
B. Policy
C. Guideline
D. Procedure

---

25 A startup wants to deploy code without managing servers or operating systems. Which cloud model fits BEST?

A. On-premises
B. PaaS
C. Colocation
D. IaaS

---

26 Developers are pasting proprietary source code into a public AI chatbot. What is the BEST first governance step?

A. Ignore it since AI improves productivity
B. Publish an AI acceptable-use policy that defines approved tools and permitted data
C. Fire all developers who used AI
D. Block the entire internet for developers

---

27 Which IP address is a private (RFC 1918) address?

A. 200.10.10.10
B. 172.20.5.10
C. 172.32.1.1
D. 8.8.8.8

---

28 A file's SHA-256 value changes after it was downloaded. What does this indicate?

A. The download was authenticated
B. The file's integrity may be compromised
C. The file is now encrypted
D. The file is more available

29 Which cloud characteristic allows resources to scale up automatically during a holiday sales spike?

A. Broad network access
B. Resource pooling
C. Rapid elasticity
D. Measured service

30 Which is a key performance indicator (KPI) for vulnerability management?

A. Number of firewalls purchased
B. Number of employees in the company
C. Percentage of critical vulnerabilities remediated within the SLA
D. Size of the security budget

31 Which wireless security protocol is the strongest current option?

A. WPA with TKIP
B. WPA3
C. Open network with MAC filtering
D. WEP

32 Which value must be less than or equal to the maximum tolerable downtime (MTD)?

A. Annualized rate of occurrence (ARO)
B. Mean time between failures (MTBF)
C. Recovery point objective (RPO)
D. Recovery time objective (RTO)

33 Why is quantum-resistant cryptography a planning concern today?

A. Hashing no longer works at all
B. It only matters for wireless networks
C. Quantum computers have already broken AES-256
D. Encrypted data captured now could be decrypted later when quantum computers mature

34 Which protocol is commonly used for federated web SSO between an enterprise and a SaaS app using XML assertions?

A. DHCP
B. SAML
C. SMTP
D. SNMP

35 A former employee's account is disabled, but their personal API token still works. What should be done?

A. Nothing, since the account is disabled
B. Revoke the token, review its activity, and fix the deprovisioning process
C. Wait for the token to expire naturally
D. Change the employee's password

---

36 A company shuts down a public file-sharing service because its risk outweighs its value. Which treatment is this?

A. Avoid
B. Transfer
C. Mitigate
D. Accept

---

37 Which is an example of a physical preventive control?

A. Bollards in front of a building entrance
B. An acceptable-use policy
C. CCTV recording
D. Intrusion detection system

---

38 A company takes a full backup Sunday and a differential every night Monday through Saturday. The server fails Thursday afternoon. What is needed to restore?

A. Every differential from Monday to Wednesday
B. Sunday's full and Wednesday night's differential
C. Sunday's full only
D. Only Wednesday's differential

---

39 Which port is used by RDP?

A. 443
B. 3389
C. 25
D. 22

---

40 Which framework catalogs real-world adversary tactics and techniques?

A. PCI DSS
B. NIST SP 800-88
C. MITRE ATT&CK
D. ISO 27001

---

41 Which device checks a laptop's patch level and antivirus status before allowing it onto the network?

A. DNS server
B. Proxy cache
C. Load balancer
D. Network access control (NAC)

---

42 Bank tellers all receive identical permissions through a Teller group. Which model is this?

A. MAC
B. DAC
C. ABAC
D. RBAC

---

43 Which term describes a weakness in a system that could be exploited?

A. Risk
B. Exploit
C. Vulnerability
D. Threat

---

44 An attacker intercepts and alters traffic between a user and a website. What is this attack?

A. SQL injection
B. Tailgating
C. On-path (man-in-the-middle)
D. Denial of service

---

45 A company buys cyber insurance to cover the financial cost of a breach. Which risk treatment is this?

A. Accept
B. Mitigate
C. Avoid
D. Transfer

---

46 During a fire alarm, a data center's doors are configured to unlock so staff can exit. What principle drives this design?

A. Separation of duties
B. Least privilege
C. Need to know
D. Human life safety takes priority over protecting assets

---

47 Which statement about containers is correct?

A. Containers cannot have vulnerabilities
B. Each container runs its own separate hypervisor
C. Containers always provide stronger isolation than VMs
D. Containers on a host typically share the host's operating system kernel

---

48 An analyst has Secret clearance but is denied a Secret file about a project she isn't assigned to. Which principle is applied?

A. Need to know
B. Defense in depth
C. Separation of duties
D. Non-repudiation

---

49 What remains after a company applies controls to reduce a risk?

A. Residual risk
B. Total risk appetite
C. Inherent risk
D. Zero risk

---

50 A vendor needs remote access to troubleshoot a production system. Which approach is BEST?

A. Named, MFA-protected, time-limited access approved for the task and logged
B. Give the vendor a domain admin account
C. Open RDP to the internet for convenience
D. A shared admin password the vendor keeps permanently

Mock exam · answers & reasoning

The colored tag shows each question's domain, so you can score yourself per domain in the tracker at the end.

1. A D3 **Rule-based access control**
A global rule applied to everyone, regardless of identity, is rule-based.

2. C D4 **Use parameterized queries and validate input**
This is SQL injection; parameterized queries stop input from being executed as code.

3. D D2 **Cold site**
Cold sites are cheapest and slowest to bring online.

4. A D4 **TCP**
TCP uses SYN, SYN-ACK, ACK; UDP is connectionless.

5. C D1 **Unique user accounts with protected audit logs**
Accountability requires tying actions to individuals, which shared accounts prevent.

6. A D5 **Ensure changes are reviewed, approved, tested and reversible to reduce risk**
Change control prevents unauthorized or untested changes from causing outages or vulnerabilities.

7. B D1 **Defense in depth**
Multiple layers of different control types so one failure isn't fatal.

8. A D2 **HIPAA**
HIPAA governs US protected health information.

9. A D3 **Just-in-time privileged access**
JIT access reduces standing privilege, a core PAM practice.

10. D D3 **A mantrap (access control vestibule)**
A mantrap allows one authenticated person at a time. Cameras detect; posters deter.

11. B D5 **Symmetric encryption such as AES**
Symmetric is fast for bulk data; hashing can't be reversed to read data.

12. C D4 **Deny all traffic not explicitly allowed**
Implicit/explicit deny ensures anything not approved is blocked.

13. B D3 **A compromised SSO credential can unlock many applications**
SSO concentrates risk, so protect it with strong MFA and monitoring.

14. C D1 **Protect society, the common good, necessary public trust and confidence, and the infrastructure**
Canons are applied in order: 1 Society, 2 Honor, 3 Principals, 4 Profession.

15. B D1 **Availability**
Authorized users can't access their data. (If data is also stolen, confidentiality is affected too, but the stem describes lost access.)

16. A D5 **Recovery: restore systems from clean sources and monitor**
Order: Preparation, Detection & Analysis, Containment, Eradication, Recovery, Lessons Learned.

17. A D2 **Parallel test**
Parallel tests prove the alternate site works without cutting over production.

18. D D2 **Keep critical business functions operating during a disruption**
BCP keeps the business running; DRP restores technology.

19. A D3 **Something you have and something you know**
The card is possession; the PIN is knowledge, so it is genuine MFA.

20. C D5 **Data masking**
Masking hides part of the data from viewers while keeping it usable.

21. C D5 **Contents of memory (RAM)**
Order of volatility: the most volatile evidence (memory) disappears at power-off.

22. D D3 **FIDO2 hardware security key or passkey**
FIDO2 cryptographically binds the login to the real site, so a fake site can't relay it.

23. D D5 **Static application security testing (SAST)**
SAST = code at rest; DAST = running application.

24. C D1 **Guideline**
Guidelines are recommendations; policies, standards and procedures are mandatory.

25. B D4 **PaaS**
PaaS provides the OS and runtime; the customer brings code and data.

26. B D2 **Publish an AI acceptable-use policy that defines approved tools and permitted data**
Govern emerging tech with policy, approved tools and data rules, then train and monitor.

27. B D4 **172.20.5.10**
Private ranges: 10/8, 172.16–172.31, 192.168/16. 172.32.x.x is outside the 172.16/12 range.

28. B D1 **The file's integrity may be compromised**
Any change to a file changes its hash, so a mismatch signals an integrity problem.

29. C D4 **Rapid elasticity**
Elasticity is the ability to scale capacity up and down quickly.

30. C D2 **Percentage of critical vulnerabilities remediated within the SLA**
KPIs measure how well a process performs against a target.

31. B D4 **WPA3**
WPA3 uses SAE; WEP is broken and MAC filtering is easily spoofed.

32. D D2 **Recovery time objective (RTO)**
If restoration takes longer than MTD, the business suffers unacceptable harm.

33. D D5 **Encrypted data captured now could be decrypted later when quantum computers mature**
'Harvest now, decrypt later' threatens long-lived secrets protected by RSA/ECC.

34. B D3 **SAML**
SAML exchanges XML-based authentication assertions between an identity provider and service provider.

35. B D3 **Revoke the token, review its activity, and fix the deprovisioning process**
Leaver processes must revoke all credentials, including tokens, keys and sessions.

36. A D1 **Avoid**
Eliminating the activity removes the risk entirely.

37. A D1 **Bollards in front of a building entrance**
Bollards physically stop vehicles. CCTV is detective; policy is administrative; IDS is technical detective.

38. B D2 **Sunday's full and Wednesday night's differential**
Each differential contains all changes since the last full, so only the latest is needed.

39. B D4 **3389**
RDP = 3389. Exposing it directly to the internet is a common ransomware entry point.

40. C D5 **MITRE ATT&CK**
ATT&CK is a knowledge base of TTPs; 800-88 is media sanitization.

41. D D4 **Network access control (NAC)**
NAC performs posture assessment before granting access.

42. D D3 **RBAC**
Permissions assigned by job role = role-based access control.

43. C D1 **Vulnerability**
A threat exploits a vulnerability; risk is the likelihood and impact of that happening.

44. C D4 **On-path (man-in-the-middle)**
On-path attacks sit between two parties; TLS with certificate validation defends against them.

45. D D1 **Transfer**
Insurance shifts financial impact to a third party; accountability stays with the company.

46. D D1 **Human life safety takes priority over protecting assets**
Fail-safe/fail-open for exits during emergencies: people always come first.

47. D D4 **Containers on a host typically share the host's operating system kernel**
Shared kernels mean a kernel exploit can affect all containers, so harden images and runtime permissions.

48. A D3 **Need to know**
Clearance alone isn't enough; access must also be required for the task.

49. A D1 **Residual risk**
Controls reduce risk but rarely eliminate it; what's left is residual.

50. A D2 **Named, MFA-protected, time-limited access approved for the task and logged**
Third-party access should be accountable, least-privilege, temporary and monitored.

Domain score tracker

Domain	My score	Pass-ready (75%)
D1 Security Principles	___ / 12	9+
D2 Security Governance	___ / 9	7+
D3 Identity & Access Management (IAM) Concepts	___ / 10	8+
D4 Networking & Cloud Security Concepts	___ / 11	8+
D5 Security Operations & Incident Response	___ / 8	6+
Total	___ / 50	40+

Error log

Log the **concept** you missed and the rule that fixes it. Review this page, not the whole guide, in the final 48 hours.

Q / Dom	Concept	Why I missed it	Correct rule	Re-test ✓

Final review sheet: the night before

D1 Principles

- CIA: disclose / alter / disrupt
- ID → AuthN → AuthZ → Accounting
- Non-repudiation = digital signature
- Risk = likelihood × impact; avoid · mitigate · transfer · accept
- ALE = SLE × ARO; SLE = AV × EF
- Only the risk owner accepts risk
- Controls: admin/technical/physical × preventive/detective/corrective/deterrent/compensating
- Policy → standard → procedure; guideline optional
- Ethics: Society · Honor · Principals · Profession (in order)
- Life safety always first

D2 Governance

- BIA first → MTD ≥ RTO; RPO = data loss
- BC = business, DR = IT
- Hot → warm → cold (cost ↓, speed ↓)
- Incremental: full + all; differential: full + last
- 3-2-1 backups; prove by restore
- Tests: checklist → tabletop → simulation → parallel → full interruption
- GDPR · HIPAA · PCI DSS (contract) · SOX
- CSF 2.0: Govern Identify Protect Detect Respond Recover
- KPI = performance; KRI = rising risk
- Compliant ≠ secure

D3 IAM

- MFA = different categories (know/have/are)
- Password + PIN ≠ MFA
- FIDO2/passkeys = phishing-resistant
- FAR (Type II) is the dangerous one
- DAC owner · MAC labels · RBAC role · ABAC attributes · rule-based global
- Least privilege, need to know, SoD
- Joiner / mover (remove old!) / leaver (revoke all tokens)
- SSO ≠ authorization; protect with MFA
- OAuth = authZ · OIDC = authN · SAML = XML SSO
- Mantrap stops tailgating

D4 Network & Cloud

- OSI: Please Do Not Throw Sausage Pizza Away
- Switch L2 · router L3 · TCP/UDP L4
- 22 SSH · 23 Telnet · 25 SMTP · 53 DNS · 80/443 · 3389 RDP
- Private: 10/8 · 172.16/12 · 192.168/16
- IDS alerts · IPS blocks · firewall filters
- DMZ for public servers; segmentation stops lateral movement
- Zero Trust: never trust, always verify
- WPA3 best; WEP broken; isolate IoT
- Customer always owns data + access
- IaaS: customer patches OS

D5 SecOps & IR

- Prep → Detect/Analyze → Contain → Eradicate → Recover → Lessons
- Contain before you clean; don't destroy evidence
- RAM before disk; hash images; chain of custody
- Encrypt to recipient's public key; sign with own private key
- Hash = integrity; salt passwords
- Clear · purge · destroy; format ≠ sanitize
- False negative is worst
- NTP for log timelines; SIEM correlates
- Scan finds · pen test exploits (authorized)
- Red attack · blue defend · purple both

Exam day

- Read the last sentence first, then the whole stem
- Circle FIRST / BEST / MOST / NOT
- Choose the manager's answer: safe, authorized, by the plan
- No going back, so commit and move on
- Pace ≈ 1 min per item; don't sink 4 minutes in one
- Hard questions mean CAT thinks you're doing well
- Bring valid ID; arrive early; sleep matters more than cramming

Don't cram: Kubernetes administration, vendor-specific cloud commands, cryptographic math, firewall syntax. CC tests concepts and judgment.

Sources & scope notes

- ISC2, *Certified in Cybersecurity Exam Outline* (effective 1 Sept 2026): isc2.org/certifications/cc/cc-certification-exam-outline
- ISC2 Insights, *Inside the Updated ISC2 CC Exam* (Aug 2026): isc2.org/Insights/2026/08/inside-the-updated-isc2-cc-exam
- CertCrush, *ISC2 CC Domains 2026: New Exam Outline Weightings*: certcrush.app (domain weights, exam format)
- Open Exam Prep, *ISC2 CC Practice Test Strategy & Domain Map 2026*: open-exam-prep.com (sub-objective topics)
- ISC2 Code of Ethics: isc2.org/ethics · NIST CSF 2.0 (2024) · NIST SP 800-88 (media sanitization) · NIST SP 800-61 (incident handling) · NIST FIPS 203/204/205 (post-quantum cryptography) · NIST SP 800-145 (cloud definition) · MITRE ATT&CK
- Source drafts reviewed: *ISC2_CC_Master_Study_Guide_ChatGPT.pdf* (55 pp) and *ISC2_CC_2026_Optimized_Pass_Focused_Study_Guide_Copilot.docx*

Domain weights are reported from ISC2's outline and third-party summaries; ISC2 rounds them so they total 99.9%. Verify the format, item count and policies on isc2.org before you book. All 110 questions here are original practice items written to mirror the style of CC scenarios. They are not recalled or leaked exam content, and no study guide can guarantee a pass.